Agente Analista de IA para SOC

Reporte de evolución de la skill de investigación

Estado de diseño, funcionamiento, mejoras y hoja de ruta

28 de septiembre de 2026 · Documento de seguimiento del proyecto

> ***Alcance y versión.*** *Este informe usa "V3" para referirse a la iteración más reciente solicitada por el equipo. En los artefactos revisados, el esquema JSON declara la versión 1.1 y el archivo de la skill no declara una versión semántica propia. Conviene formalizar esa nomenclatura antes de presentar una release.*

Contenido

1. Resumen ejecutivo
2. Asignación y límites del proyecto
3. Funcionamiento de la skill
4. Ajustes y mejoras de la iteración V3
5. Cumplimiento frente al encargo de la empresa
6. Evidencia disponible de las pruebas
7. Mejoras recomendadas
8. Conclusión
9. Siguiente hito de trabajo
10. Base documental revisada

Resumen ejecutivo

El documento del proyecto asigna al equipo la capa de investigación de un SOC: recibir un caso de alertas correlacionadas, formular hipótesis sustentadas, reconstruir su secuencia y alcance y entregar un reporte que pueda revisar un analista. El cliente ya cuenta con flujos para enriquecer IoC, notificar y generar plantillas. La skill se diseñó para trabajar sobre la investigación sin duplicar esas funciones.

La primera entrega es una guía operativa para que un agente de IA aplique un procedimiento de investigación, acompañada por un protocolo, un esquema JSON versionado, una plantilla de reporte y un validador local. Define seis etapas consecutivas, exige trazabilidad a alertas fuente, consume solo el enriquecimiento adjunto y deja la

decisión final al analista. No constituye todavía un servicio desplegado: no incluye el backend completo, la interfaz web, el grafo de ejecución persistente ni una integración con Elastic, Wazuh o un gestor de casos.

La iteración revisada mejora el tratamiento del alcance: diferencia los activos donde se observó actividad de los que tienen impacto o compromiso confirmado. La última prueba encontró que el validador aceptaba referencias rotas en esa sección; se corrigió el contrato y la validación. Los dos ensayos disponibles cubren phishing con credenciales y fuerza bruta con posible movimiento lateral. No miden la precisión estadística, el rendimiento para 50 alertas ni el umbral del 99% mencionado en la conversación. Ese porcentaje no aparece como requisito en el documento de la empresa.

1. Asignación y límites del proyecto

El cliente describe un prototipo académico con un proveedor de SOC gestionado. Su entorno usa Elastic y Wazuh; el material de desarrollo debe ser simulado o anonimizado y no requiere acceso a producción. El foco asignado es la capa que investiga un caso, no el enriquecimiento básico de IoC.

La entrega del equipo comprende seis capacidades: un agente analista; una metodología basada en MITRE ATT&CK; una cronología con acceso inicial, progresión y blast radius; consumo del enriquecimiento existente; reportes legibles y JSON; y una interfaz donde la persona analista pueda validar o corregir hallazgos antes de cerrar el caso.

Entre las exigencias no funcionales, el documento fija una investigación completa en cinco minutos como máximo para casos de hasta 50 alertas, trazabilidad de cada conclusión a datos concretos, despliegue web en contenedores y revisión concurrente de varios casos. También solicita un dataset simulado con cuatro familias: phishing y robo de credenciales, fuerza bruta con movimiento lateral, exfiltración y actividad previa a ransomware.

La skill cubre el procedimiento de investigación que corresponde al agente. No reemplaza el resto del producto ni acredita por sí sola que se cumplan esos objetivos de servicio.

2. Funcionamiento de la skill

La instrucción principal exige respetar este orden incluso cuando falten datos. En ese caso, registra la limitación y continúa sin completar campos por intuición.

Etapa	Trabajo del agente	Control o salida
1. Recibir y validar	Identificar ECS, Elastic Security o Wazuh; revisar cantidad, campos, IDs y timestamps.	Resumen de entrada y datos faltantes.
2. Investigar patrones	Correlacionar señales y proponer hipótesis con MITRE ATT&CK, evidencia a favor y en contra y alternativas.	Hipótesis ordenadas y mapeos candidatos; las etiquetas no se tratan como confirmación.
3. Reconstruir tiempo y alcance	Normalizar timestamps a UTC, conservar originales e identificar entidades por rol.	Timeline y blast radius que separa activos observados de impacto confirmado, sospechoso o desconocido.
4. Consumir IoC provistos	Relacionar los resultados ya incluidos en el caso con sus indicadores y alertas.	Fuente y coincidencias exactas; sin búsquedas ni enriquecimiento propio.
5. Generar y validar el reporte	Preparar resumen legible y JSON según el esquema, con evidencia, incertidumbres y recomendaciones.	Validador local para estructura y referencias a alertas.
6. Entregar a revisión humana	Mantener el caso pendiente para que el analista acepte, edite o rechace los hallazgos.	`review.status` permanece en `pending`; no hay cierre ni respuesta automática.

El diseño usa confianza ordinal (`alta`, `media`, `baja` o `insuficiente`) y explica qué datos sostienen cada juicio. No convierte “alta” en 99%. La explicación que se expone al analista se centra en la observación, los campos fuente y la inferencia asociada, de modo que pueda auditarla y corregirla.

La arquitectura recomendada para convertir el procedimiento en aplicación es un workflow explícito en LangGraph, con estado tipado y persistente. La skill actual no ejecuta ese grafo: codifica la secuencia como instrucciones y recursos para el agente. La aplicación deberá registrar las transiciones para demostrar que las fases no se saltaron ni cambiaron de orden.

3. Ajustes y mejoras de la iteración V3

Los cambios comprobados en la última iteración se concentran en la precisión del alcance y su auditabilidad:

- **Actividad observada separada del compromiso.** El reporte ahora lista `observed_assets` por separado de `confirmed_assets` y `suspected_assets`. Que un host aparezca en una alerta no basta para afirmar que fue comprometido.
- **Contrato de salida 1.1.** El esquema requiere que cada activo observado incluya su nombre, una descripción de actividad y los IDs de alerta que lo sustentan. Los activos sospechosos o confirmados e identidades declaradas también necesitan referencias fuente.
- **Validación de referencias del blast radius.** El validador contrasta esos IDs con los registros de entrada. Antes de esta corrección, aceptaba una referencia inexistente en `observed_assets`.
- **Prueba negativa añadida.** Al sustituir un ID válido por `not-an-alert`, la versión actual informa el error y falla la validación. También se comprobó que el esquema rechaza un reporte sin `observed_assets`.
- **Cautela ante señales ambiguas.** En la prueba Wazuh, el acceso SSH a `db-02` coincidió con un job legítimo de respaldo. La skill dejó esa actividad como observada y el movimiento lateral como candidato, sin afirmar causalidad ni exfiltración.

La secuencia de seis etapas se mantuvo. El ajuste no agrega búsquedas de reputación, acciones de respuesta ni acceso a producción. La trazabilidad automática sigue teniendo límites: verifica IDs y estructura, pero todavía no confirma que los campos citados existan en la alerta ni que cada descripción reproduzca correctamente sus valores.

4. Cumplimiento frente al encargo de la empresa

Exigencia	Estado en la skill/prototipo	Alcance comprobado y pendiente
Entrada ECS o Wazuh con datos simulados	Parcial	La secuencia acepta ambos formatos y se probaron un fixture ECS y uno Wazuh. Falta una validación completa contra sus esquemas nativos y exportaciones anonimizadas del cliente.
Metodología MITRE ATT&CK e hipótesis con evidencia	Parcial	La skill exige mapear comportamientos, citar evidencia a favor/en contra y ordenar hipótesis. Falta una biblioteca ATT&CK local, fijada y verificable dentro de un motor implementado.

Exigencia	Estado en la skill/prototipo	Alcance comprobado y pendiente
Timeline y blast radius	Parcial	Se probó la cronología y se incorporó la distinción de activos observados. La cobertura actual se limita a los casos sintéticos revisados.
Consumo de IoC ya enriquecidos	Cubierto como procedimiento	La regla indica usar solo el payload de entrada. Se usó un feed simulado; no se probó el contrato real de salida del flujo del cliente.
Reporte legible y JSON	Parcial	Existe una salida de prueba legible, un JSON y un esquema v1.1. No se ha comprobado la ingestión en TheHive u otro gestor.
Revisión y corrección por analista	Parcial	Los reportes quedan pendientes y no ejecutan acciones. La interfaz web de revisión no está construida.
Auditoría de conclusiones	Parcial	Se verifican referencias a alertas en mapeos, hipótesis, timeline, recomendaciones y blast radius. Faltan la validación semántica de campos y la cobertura completa de referencias de enriquecimiento.
Hasta 50 alertas en no más de cinco minutos	Pendiente	No se ejecutó una prueba de carga ni se midió latencia.
Aplicación web en contenedores y varios casos abiertos	Pendiente	La skill y el validador no son una aplicación desplegada ni una interfaz concurrente.
Cuatro familias de escenarios y demo grabada	Parcial	Hay dos smoke tests sintéticos: phishing con credenciales y fuerza bruta con posible movimiento lateral. Exfiltración, actividad previa a ransomware y demo completa siguen pendientes.

La restricción de no usar producción se respetó durante estas pruebas. El documento de la empresa exige trazabilidad y un máximo de cinco minutos para 50 alertas; no fija un porcentaje de precisión del 99%. Esa cifra debe tratarse como una meta de evaluación propuesta, no como un resultado ni como una aceptación ya alcanzada.

5. Evidencia disponible de las pruebas

Ambas fueron pruebas manuales de conformidad sobre fixtures sintéticos; no son ejecuciones de una aplicación de agente desplegada.

Prueba ECS: phishing y uso posible de credenciales

El primer smoke test utilizó seis alertas simuladas, IoC adjunto y texto hostil incluido en el campo del correo. La aplicación manual de la skill trató ese texto como dato no confiable, mantuvo las seis etapas, dejó ATT&CK como candidato cuando el ID no estaba verificado y no afirmó robo confirmado, movimiento lateral, exfiltración ni ransomware. El reporte pasó el esquema y el validador. Esta prueba confirma el comportamiento del procedimiento frente a ese fixture; no mide tasa de detección.

Prueba Wazuh: fuerza bruta y actividad de respaldo

En el segundo recorrido manual se analizaron diez alertas con offset horario explícito. Cuatro fallos para `deploy` desde `203.0.113.88` fueron seguidos por un login exitoso y uso de `sudo` en `web-01`. En `db-02` se registraron SSH para `svc_backup`, un timer de respaldo, ejecución de `tar` y creación local de un archivo. El reporte mantuvo el compromiso de `web-01` como posible y la actividad de `db-02` como ambigua.

La IP y el feed de reputación del caso son ficticios; la dirección pertenece a TEST-NET-3, reservado para documentación. El informe señaló esa condición y no la presentó como inteligencia de amenazas real. Las referencias se probaron con una entrada válida y una referencia rota. El reporte válido pasó el esquema Draft 2020-12 y la skill pasó el validador de formato.

Ninguna prueba establece precisión estadística, desempeño con casos reales, carga de 50 alertas ni una tasa de falsos positivos aceptable.

6. Mejoras recomendadas

Prioridad	Trabajo propuesto	Criterio de salida
1	Completar fixtures de las cuatro familias y añadir casos benignos, ambiguos, con datos ausentes y texto adversarial. Obtener etiquetas separadas revisadas por analistas.	Cada familia tiene casos positivos y negativos; las etiquetas no se filtran al análisis.
2	Endurecer la validación: comprobar existencia y valor real de los campos citados, fechas y zonas horarias, IDs duplicados, alertas omitidas y `matched_alert_ids` del payload IoC.	Errores reproducibles y trazas que señalen ruta JSON, ID y causa.
3	Medir calidad antes de hablar de 99%: exactitud por tipo de hallazgo, precisión, recall, F1, falsos positivos/negativos, abstención y calibración de confianza.	Resultados sobre un conjunto de prueba independiente, con denominadores y condiciones publicados.
4	Implementar el backend Python como workflow con estado persistente y auditoría por etapa; usar salidas estructuradas y catálogo ATT&CK local versionado.	Se demuestra el orden de fases y se reproduce el mismo reporte con el mismo input y versiones registradas.
5	Medir latencia por etapa y probar hasta 50 alertas; registrar p50/p95 y entorno de ejecución.	Evidencia de cumplimiento del límite de cinco minutos, o una brecha cuantificada.
6	Construir la interfaz de borrador, revisión y corrección, y luego desplegarla en contenedores con varios casos concurrentes.	Un analista puede revisar y corregir sin cierre automático; pruebas de seguridad y concurrencia documentadas.
7	Probar compatibilidad del JSON con un gestor de casos y con el payload real de enriquecimiento del cliente. Grabar la demo desde la ingesta hasta la revisión.	Integración de prueba demostrable, sin afirmar acceso a producción ni funciones no implementadas.

La meta del 99% requiere definir qué se clasifica como una asignación correcta y reunir suficientes casos independientes. Una salida bien formada o una prueba sintética exitosa no sirven como sustituto de esa medición.

Conclusión

La skill proporciona una base metodológica alineada con la responsabilidad asignada al agente: investigar señales, ordenar hipótesis, reconstruir la cronología, citar evidencia, consumir IoC existentes y dejar la decisión a una persona analista. La mejora de V3 más visible en la prueba es una representación del alcance que distingue actividad de compromiso y rechaza IDs fuente inexistentes.

El avance es una primera capa del proyecto, no el prototipo completo que describe la empresa. Para llegar a ese objetivo, las siguientes entregas deben ampliar el dataset, reforzar las comprobaciones semánticas, implementar el workflow y la interfaz y medir los objetivos de auditabilidad, latencia y calidad con analistas.

Siguiente hito de trabajo

Antes de iniciar la interfaz, conviene cerrar la evaluación metodológica: completar los cuatro escenarios, incorporar casos benignos y ambiguos y revisar las etiquetas con analistas. El punto de salida sería un conjunto de pruebas reproducible, reglas de aceptación acordadas y una versión formal de la skill y su esquema. Con esa base se puede implementar el workflow Python y medir su latencia sin confundir el resultado del prototipo con una meta de precisión aún no evaluada.

Base documental revisada

- *Agente Analista de IA para SOC — Descripción del proyecto*, documento proporcionado, 27 de septiembre de 2026.
- Plan de estudio y diseño del agente SOC.
- Resultado del smoke test ECS de phishing.
- Resultado de la prueba Wazuh de fuerza bruta y respaldo ambiguo.
- Skill `soc-case-investigator`, protocolo, plantilla, esquema JSON 1.1 y validador local.